

PrivEsc Linux — SUDO MAKE ME A SANDWICH

Élévation de privilèges via configuration Sudo permissive (Emacs)

PLATEFORME : picoCTF
2026

CATÉGORIE : General Skills /
PrivEsc

DIFFICULTÉ / AUTEUR : Easy /
Darkraicg492

FLAG : Présent dans flag.txt (lu via Emacs avec privilèges root)

//# 1. OBJECTIF & RÉSUMÉ DE LA VULNÉRABILITÉ

L'objectif de ce challenge est d'obtenir des privilèges administratifs (`root`) ou de contourner les restrictions de lecture du système de fichiers afin de lire le contenu de `flag.txt` accessible uniquement en superutilisateur.

La vulnérabilité repose sur une ****mauvaise configuration du fichier `/etc/sudoers` **** : l'utilisateur non privilégié `ctf-player` possède l'autorisation d'exécuter l'éditeur de texte `/bin/emacs` en tant que `root` sans avoir à fournir de mot de passe (`NOPASSWD`).

CONCEPT CLÉ CYBERSÉCURITÉ : ABUS DE BINAIRES SUDO & PRINCIPE DU MOINDRE PRIVILÈGE

Accorder des droits `sudo` sur des éditeurs de texte complets (comme `emacs`, `vim` ou `nano`) annule toute restriction d'accès au système de fichiers. Un utilisateur disposant de ce privilège peut lire/écrire n'importe quel fichier sensible système ou faire spawner un shell superutilisateur direct.

//# 2. OUTILS & CONCEPTS CLÉS

Outil / Concept	Rôle & Utilisation dans le CTF
<code>sudo -l</code>	Commande d'énumération essentielle sous Linux permettant de lister les règles d'exécution autorisées dans <code>/etc/sudoers</code> .
<code>/bin/emacs</code>	Éditeur de texte complexe dont l'exécution avec privilèges <code>root</code> permet la lecture et l'édition directe de fichiers protégés.
GTFOBins	Base de connaissances de référence répertoriant la liste des binaires Unix légitimes et la méthode pour les détourner.
Élévation de Privilèges (PrivEsc)	Phase post-exploitation visant à passer d'un compte utilisateur restreint à des privilèges administratifs complets.

//# 3. DÉMARCHE PAS À PAS (MÉTHODOLOGIE)

Étape 1 : Connexion & Énumération des Privilèges Sudo

Après connexion en SSH sur la machine distante, une première tentative de lecture directe de `flag.txt` échoue en raison de permissions insuffisantes (`Permission denied`).

Le réflexe d'énumération consistant à tester `sudo -l` révèle les privilèges accordés :

```
ctf-player@challenge:~$ sudo -l
Matching Defaults entries for ctf-player on challenge:
    env_reset, mail_badpass, secure_path=/usr/local/sbin:...
```

```
User ctf-player may run the following commands on challenge:
(ALL) NOPASSWD: /bin/emacs
```

Étape 2 : Analyse du Binaire Autorisé

L'analyse de la ligne `(ALL) NOPASSWD: /bin/emacs` montre que le binaire `emacs` peut être exécuté par l'utilisateur courant sous l'identité de n'importe quel utilisateur (dont `root`) sans mot de passe.

Étape 3 : Exploitation & Lecture du Flag

Pour lire le fichier protégé `flag.txt`, il suffit d'invoquer `emacs` en superutilisateur en lui passant directement le chemin du fichier cible en paramètre :

```
sudo /bin/emacs flag.txt
```

L'interface textuelle d'Emacs s'ouvre alors avec des droits `root`, chargeant le contenu du fichier `flag.txt` à l'écran et permettant d'extraire le flag.

(Alternative [GTFOBins](#) pour l'obtention d'un shell root direct) :

```
sudo /bin/emacs --eval '(term)'
```

///**# 4. MÉMENTO TECHNIQUE (CHEATSHEET PRIVESC SUDO)**

Binaires d'édition / lecture et contournements Sudo fréquents :

Binaire Sudo	Méthode d'obtention de Shell / Lecture Root
<code>emacs</code>	<code>sudo emacs --eval '(term)'</code> ou ouverture directe du fichier cible.
<code>vim</code> / <code>vi</code>	Lancer <code>sudo vim</code> puis saisir <code>:!sh</code> ou <code>:set shell=/bin/sh</code> puis <code>:shell</code> .
<code>less</code> / <code>more</code>	Lancer <code>sudo less /etc/profile</code> puis saisir <code>!/bin/sh</code> .
<code>nano</code>	Lancer <code>sudo nano</code> , puis faire <code>Ctrl+R</code> puis <code>Ctrl+X</code> pour exécuter une commande shell.

///**# 5. LEÇONS RETENUES & REFLEXES À GARDER**

AUTOMATISMES LINUX PRIVESC

- **Systématique `sudo -l`** : L'exécution de `sudo -l` est le premier réflexe absolu lors de la phase d'énumération locale sur un système Linux.
- **Référentiel GTFOBins** : Dès qu'un binaire apparaît dans la liste des commandes `sudo` ou possède le bit `SUID`, consulter immédiatement [GTFOBins](#) pour identifier le vecteur d'abus.
- **Hardening / Sécurisation** : Ne jamais attribuer de privilèges `sudo` sur des applications interactives permettant d'exécuter des sous-processus ou de manipuler arbitrairement le système de fichiers.